

ΠΡΟΣΤΑΣΙΑ ΕΞΥΠΗΡΕΤΗΤΩΝ ΜΕ ΧΡΗΣΗ SSH ΚΑΙ FAIL2BAN

Όνομα: Βασίλης Κουμεντέας

ΑΜ: 1083637

Μάθημα: Σύγχρονες Εφαρμογές Ασφάλειας
Δικτύων

Εργασία 1

Αρχικά βλέπουμε αν εγκαταστάθηκαν τα αρχεία που ζητούνται να ανατρέξουμε εκτελώντας την εντολή `ls /etc/fail2ban`:

```
blaxos111333444@10:~$ ls /etc/fail2ban
action.d      fail2ban.d    jail.conf     jail.local    paths-common.conf  paths-opensuse.conf
fail2ban.conf filter.d      jail.d        paths-arch.conf paths-debian.conf
blaxos111333444@10:~$ ls /etc/fail2ban/filter.d
3proxy.conf      dovecot.conf      mysqld-auth.conf      selinux-common.conf
apache-auth.conf  dropbear.conf      nagios.conf           selinux-ssh.conf
apache-badbots.conf  drupal-auth.conf   named-refused.conf    sendmail-auth.conf
apache-botsearch.conf  ejabberd-auth.conf nginx-bad-request.conf sendmail-reject.conf
apache-common.conf    exim-common.conf   nginx-botsearch.conf  sieve.conf
apache-fakegooglebot.conf  exim.conf          nginx-http-auth.conf  slapd.conf
apache-modsecurity.conf  exim-spam.conf     nginx-limit-req.conf  softethervpn.conf
apache-nohome.conf      freeswitch.conf     nsd.conf              sogo-auth.conf
apache-noscript.conf    froxlor-auth.conf   openhab.conf          solid-pop3d.conf
apache-overflows.conf   gitlab.conf         openwebmail.conf      squid.conf
apache-pass.conf        grafana.conf        oracleims.conf        squirrelmail.conf
apache-shellshock.conf  groupoffice.conf    pam-generic.conf      sshd.conf
assp.conf              gssftpd.conf        perdition.conf        stunnel.conf
asterisk.conf           guacamole.conf      phpmyadmin-syslog.conf suhosin.conf
bitwarden.conf          haproxy-http-auth.conf  php-url-fopen.conf    tine20.conf
botsearch-common.conf  horde.conf           portentry.conf         traefik-auth.conf
centreon.conf           ignorecommands      postfix.conf           uwimap-auth.conf
common.conf             kerio.conf           proftpd.conf           vsftpd.conf
counter-strike.conf     lighttpd-auth.conf   pure-ftpd.conf         webmin-auth.conf
courier-auth.conf        mongod-auth.conf     qmail.conf             wuftpd.conf
courier-smtp.conf        monit.conf           recidive.conf          xinetd-fail.conf
cyrus-imap.conf          monitorix.conf        roundcube-auth.conf    znc-adminlog.conf
directadmin.conf         mssql-auth.conf      scanlogd.conf          zoneminder.conf
domino-smtp.conf         murmur.conf          screensharingd.conf
```

- 1) Εκτελούμε τις εντολές `sudo fail2ban-client status` και `sudo fail2ban-client status sshd` και βρίσκουμε:

```
blaxos111333444@10:~$ sudo fail2ban-client status
Status
|- Number of jail:      1
`- Jail list:  sshd
blaxos111333444@10:~$ sudo fail2ban-client status sshd
Status for the jail: sshd
|- Filter
| |- Currently failed: 0
| |- Total failed:    1
| `-- Journal matches: _SYSTEMD_UNIT=sshd.service + _COMM=sshd
`- Actions
  |- Currently banned: 0
  |- Total banned:    0
  `-- Banned IP list:
blaxos111333444@10:~$
```

- 2) Εκτελούμε την εντολή `sudo nano /etc/fail2ban/jail.conf` για να μπούμε στο αρχείο διαμόρφωσης:

```
GNU nano 7.2 /etc/fail2ban/jail.conf
# "ignoreself" specifies whether the local resp. own IP addresses should be ignored
# (default is true). Fail2ban will not ban a host which matches such addresses.
ignoreself = true

# "ignoreip" can be a list of IP addresses, CIDR masks or DNS hosts. Fail2ban
# will not ban a host which matches an address in this list. Several addresses
# can be defined using space (and/or comma) separator.
ignoreip = 127.0.0.1/8 ::1

# External command that will take an tagged arguments to ignore, e.g. <ip>,
# and return true if the IP is to be ignored. False otherwise.
#
# ignorecommand = /path/to/command <ip>
ignorecommand =

# "bantime" is the number of seconds that a host is banned.
bantime = 10m

# A host is banned if it has generated "maxretry" during the last "findtime"
# seconds.
findtime = 10m

# "maxretry" is the number of failures before a host get banned.
maxretry = 5
```

- 3) Δημιουργώντας έναν άλλον user, ανοίγουμε ένα δεύτερο τερματικό και προσπαθούμε να μπούμε με ssh `blaxos111333444@192.168.2.9`, θέλοντας να κάνουμε πέντε φορές λάθος:

The screenshot shows a terminal window with the following content:

```
blaxos111333444@10: ~
CPU: 685ms
CGroup: /system.slice/ssh.service
└─571 sshd: /usr/sbin/sshd -D [listener] 0 of 10-100 active
Nov 05 21:44:30 10 sshd[2664]: Connection closed by authenticat
Nov 05 21:44:30 10 sshd[2666]: Connection closed by authenticat
Nov 05 21:45:19 10 sshd[2668]: Connection closed by authenticat
Nov 05 22:02:08 10 sshd[2745]: Accepted publickey for blaxos111
Nov 05 22:02:08 10 sshd[2745]: pam_unix(sshd:session): session
Nov 05 22:02:08 10 sshd[2745]: pam_env(sshd:session): deprecate
Nov 05 22:04:00 10 sshd[2798]: Accepted publickey for blaxos111
Nov 05 22:04:00 10 sshd[2798]: pam_unix(sshd:session): session
Nov 05 22:04:00 10 sshd[2798]: pam_env(sshd:session): deprecate
Nov 05 22:06:16 10 sshd[2914]: Connection closed by authenticat
lines 1-23/23 (END)
blaxos111333444@10:~$ sudo nano /etc/ssh/sshd_config
blaxos111333444@10:~$ sudo nano /etc/ssh/sshd_config
blaxos111333444@10:~$ sudo systemctl restart ssh
blaxos111333444@10:~$ sudo fail2ban-client status sshd
Status for the jail: sshd
|- Filter
| - Currently failed: 0
| - Total failed: 6
| - Journal matches: _SYSTEMD_UNIT=sshd.service + _COMM=sshd
-- Actions
| - Currently banned: 1
| - Total banned: 1
| - Banned IP list: 192.168.2.9
blaxos111333444@10:~$
```

Warning: Permanently added '192.168.2.9' (ED25519) to the list of known ho:
blaxos111333444@192.168.2.9: Permission denied (publickey).
blaxos2@10:~\$ ssh blaxos111333444@10.0.2.15
blaxos2@10:~\$ ssh blaxos111333444@192.168.2.9
blaxos111333444@192.168.2.9: Permission denied (publickey).
blaxos2@10:~\$ sudo ufw status
[sudo] password for blaxos2:
blaxos2 is not in the sudoers file.
blaxos2@10:~\$ ufw status
ERROR: You need to be root to run this script
blaxos2@10:~\$ ssh blaxos111333444@192.168.2.9
blaxos111333444@192.168.2.9's password:
Permission denied, please try again.
blaxos111333444@192.168.2.9's password:
Permission denied, please try again.
blaxos111333444@192.168.2.9's password:
blaxos111333444@192.168.2.9: Permission denied (publickey,password).
blaxos2@10:~\$ ssh blaxos111333444@192.168.2.9
blaxos111333444@192.168.2.9's password:
Permission denied, please try again.
blaxos111333444@192.168.2.9's password:
Permission denied, please try again.
blaxos111333444@192.168.2.9's password:
Permission denied, please try again.
blaxos111333444@192.168.2.9's password:

Βλέπουμε ότι μετά τις πέντε φορές, δεν μας αφήνει να προσπαθήσουμε άλλο και μας βάζει στην λίστα των banned IPs.

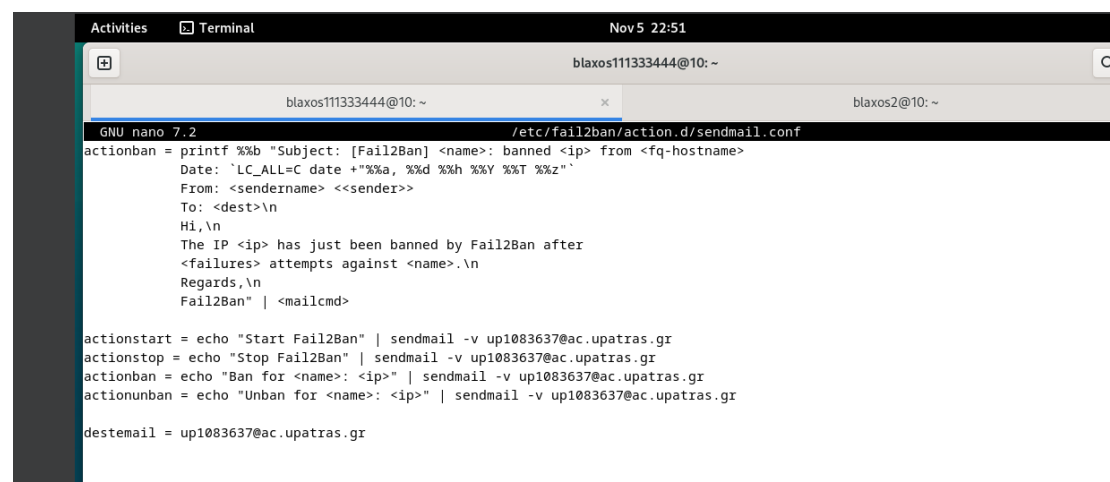
- 4) Εκτελώντας την εντολή `sudo tail /var/log/fail2ban.log`, βλέπουμε το αρχείο που καταγράφονται οι συνδέσεις:

```
sudo: /var/log/fail2ban.log: command not found
blaxos111333444@10:~$ sudo tail /var/log/fail2ban.log
2024-11-05 21:27:55,212 fail2ban.transmitter [550]: ERROR Jail 'nextcloud' skipped, because of wrong configuration: Unable to read the filter 'nextcloud'
2024-11-05 21:27:55,218 fail2ban.jail [550]: INFO Jail 'sshd' started
2024-11-05 21:27:55,282 fail2ban.filterssystemd [550]: INFO [sshd] Jail is in operation now (process new journal entries)
2024-11-05 21:36:25,150 fail2ban.filter [550]: INFO [sshd] Found 192.168.2.10 - 2024-11-05 21:36:24
2024-11-05 22:10:27,198 fail2ban.filter [550]: INFO [sshd] Found 192.168.2.9 - 2024-11-05 22:10:26
2024-11-05 22:10:33,887 fail2ban.filter [550]: INFO [sshd] Found 192.168.2.9 - 2024-11-05 22:10:33
2024-11-05 22:10:39,197 fail2ban.filter [550]: INFO [sshd] Found 192.168.2.9 - 2024-11-05 22:10:38
2024-11-05 22:11:01,197 fail2ban.filter [550]: INFO [sshd] Found 192.168.2.9 - 2024-11-05 22:11:00
2024-11-05 22:11:05,197 fail2ban.filter [550]: INFO [sshd] Found 192.168.2.9 - 2024-11-05 22:11:04
2024-11-05 22:11:05,529 fail2ban.actions [550]: NOTICE [sshd] Ban 192.168.2.9
blaxos111333444@10:~$
```

- 5) Αφότου περάσουν τα 10 λεπτά bantime, εκτελώντας ξανά `fail2ban-client status sshd` βλέπουμε ότι η banned IP έχει βγει από την λίστα:

```
2024-11-05 22:11:05,197 fail2ban.filter [550]: INFO [sshd] Found 192.168.2.9 - 2024-11-0
2024-11-05 22:11:05,529 fail2ban.actions [550]: NOTICE [sshd] Ban 192.168.2.9
blaxos111333444@10:~$ sudo fail2ban-client status sshd
Status for the jail: sshd
|- Filter
| |- Currently failed: 0
| |- Total failed: 6
| `-- Journal matches: _SYSTEMD_UNIT=sshd.service + _COMM=sshd
`- Actions
  |- Currently banned: 0
  |- Total banned: 1
  `-- Banned IP list:
blaxos111333444@10:~$
```

- 6) Για να κάνουμε unban μια IP, εκτελούμε την εντολή: `sudo fail2ban-client set sshd unbanip your_blocked_ip`. Δεν χρειάζεται στην προκειμένη περίπτωση να την εκτελέσω διότι, όπως είδαμε και πριν, πέρασε ο χρόνος bantime.
- 7) Στο αρχείο `jail.local` μπορούμε να προσθέσουμε IP που δεν θέλουμε να φιλτράρονται με την εντολή `sudo nano /etc/fail2ban/jail.local`.
- 8) Εκτελώντας την εντολή `sudo apt install sendmail`, κατεβάζουμε το πακέτο `sendmail` στην μηχανή μας. Μπαίνοντας μετά στο `sudo nano /etc/fail2ban/action.d/sendmail.conf`:



```
Activities Terminal Nov5 22:51
blaxos111333444@10: ~
blaxos111333444@10: ~
blaxos2@10: ~
GNU nano 7.2 /etc/fail2ban/action.d/sendmail.conf
actionban = printf %b "Subject: [Fail2Ban] <name>: banned <ip> from <fq-hostname>
Date: '%LC_ALL=C date +%a, %d %h %Y %T %z'"
From: <sendername> <<sender>>
To: <dest>\n
Hi,\n
The IP <ip> has just been banned by Fail2Ban after
<failures> attempts against <name>.\n
Regards,\n
Fail2Ban" | <mailcmd>

actionstart = echo "Start Fail2Ban" | sendmail -v up1083637@ac.upatras.gr
actionstop = echo "Stop Fail2Ban" | sendmail -v up1083637@ac.upatras.gr
actionban = echo "Ban for <name>: <ip>" | sendmail -v up1083637@ac.upatras.gr
actionunban = echo "Unban for <name>: <ip>" | sendmail -v up1083637@ac.upatras.gr

destemail = up1083637@ac.upatras.gr
```

(βάζοντας τα: `actionstart,actionstop,actionban,actionunban, destemail`)

Και στο `sudo nano /etc/fail2ban/jail.local`:

```
#
[sshd]
# To use more aggressive sshd modes set filter parameter "mode" in jail.local:
# normal (default), ddos, extra or aggressive (combines all).
# See "tests/files/logs/sshd" or "filter.d/sshd.conf" for usage example and details.
#mode = normal
port = ssh
logpath = %(sshd_log)s
backend = %(sshd_backend)s
action = %(action_mwl)s

[dropbear]
port = ssh
logpath = %(dropbear_log)s
```

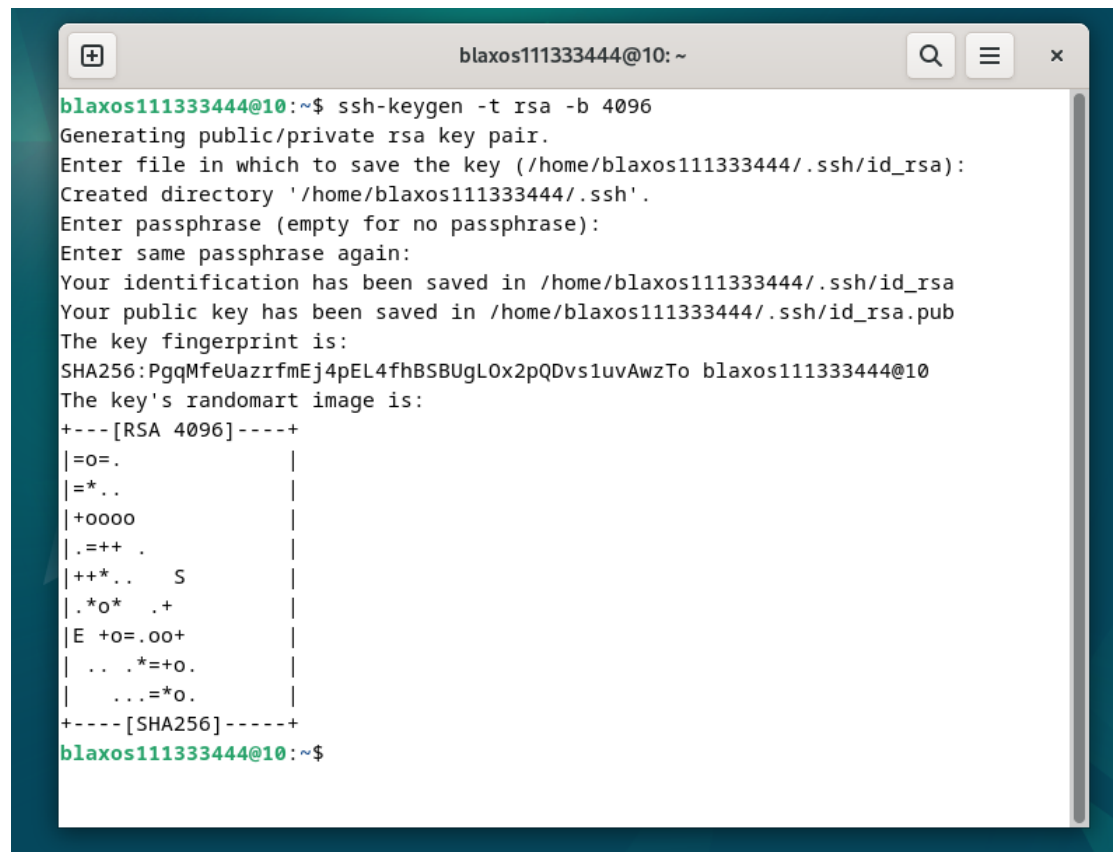
(βάζοντας το action στο sshd)

Και κάνοντας `systemctl restart fail2ban`, για να γίνουν οι αλλαγές, στέλνουμε μιλ.
(Δυστυχώς δεν κατάφερα να το πετύχω).

Εργασία 2

Εκτελούμε τα εξής βήματα:

- 1) Εκτελούμε την εντολή `ssh-keygen -t rsa -b 4096` για την δημιουργία κλειδιού.



```
blaxos111333444@10: ~
blaxos111333444@10:~$ ssh-keygen -t rsa -b 4096
Generating public/private rsa key pair.
Enter file in which to save the key (/home/blaxos111333444/.ssh/id_rsa):
Created directory '/home/blaxos111333444/.ssh'.
Enter passphrase (empty for no passphrase):
Enter same passphrase again:
Your identification has been saved in /home/blaxos111333444/.ssh/id_rsa
Your public key has been saved in /home/blaxos111333444/.ssh/id_rsa.pub
The key fingerprint is:
SHA256:PgqMfeUazrfmEj4pEL4fhBSBUgLOx2pQDvs1uvAwzTo blaxos111333444@10
The key's randomart image is:
+---[RSA 4096]---+
|o=.          |
|=*..         |
|+oooo        |
|. =++ .      |
|++*..  S     |
|.*O*  .+     |
|E +o=.oo+    |
| .. .*+=o.   |
| .. =*o.     |
+-----[SHA256]-----+
blaxos111333444@10:~$
```

- 2) Στην συνέχεια αντιγράφουμε το κλειδί σε άλλον server (θα το κάνουμε σε άλλο virtual machine στον ίδιο υπολογιστή) με την εντολή: `ssh-copy-id username@ip`, όπου το username και το ip είναι του άλλου υπολογιστή όπου θέλουμε να στείλουμε το κλειδί.

```
ssn_config.a ssn_nost_ecasa_key ssn_nost_eazssiv_key.pub
blaxos111333444@10:~$ ssh-copy-id feidas111333444@192.168.2.10
/usr/bin/ssh-copy-id: INFO: attempting to log in with the new key(s), to filter out any that are
already installed
/usr/bin/ssh-copy-id: INFO: 1 key(s) remain to be installed -- if you are prompted now it is to
install the new keys
feidas111333444@192.168.2.10: Permission denied (publickey).
blaxos111333444@10:~$
```

(Δυστυχώς, δεν κατάφερα να το κάνω να τρέξει και δοκίμασα ότι μπορούσα με τις τωρινές μου δυνατότητες, αν υπάρχει πρόβλημα στείλτε μου μιλ στο up1083637@ac.upatras.gr)

- 3) Για να ενεργοποιήσουμε στην εικονική μηχανή την ssh πρόσβαση μόνο με χρήση δημόσιου κλειδιού πρέπει να εκτελέσουμε την εντολή: `sudo nano /etc/ssh/sshd_config` και να αλλάξουμε τα `PasswordAuthentication = no` και το `PubkeyAuthentication = yes`.

```
GNU nano 7.2 /etc/ssh/sshd_config
#MaxSessions 10

#PubkeyAuthentication yes

# Expect .ssh/authorized_keys2 to be disregarded by default in future.
#AuthorizedKeysFile .ssh/authorized_keys .ssh/authorized_keys2

#AuthorizedPrincipalsFile none

#AuthorizedKeysCommand none
#AuthorizedKeysCommandUser nobody

# For this to work you will also need host keys in /etc/ssh/ssh_known_hosts
#HostbasedAuthentication no
# Change to yes if you don't trust ~/.ssh/known_hosts for
# HostbasedAuthentication
#IgnoreUserKnownHosts no
# Don't read the user's ~/.rhosts and ~/.shosts files
#IgnoreRhosts yes

# To disable tunneled clear text passwords, change to no here!
#PasswordAuthentication no
#PermitEmptyPasswords no

^G Help      ^O Write Out ^W Where Is  ^K Cut       ^T Execute   ^C Location
^X Exit      ^R Read File ^\ Replace   ^U Paste     ^J Justify   ^_ Go To Line
```

Αφού τα αλλάξουμε, αποθηκεύουμε τις αλλαγές και εκτελούμε την εντολή `sudo systemctl restart ssh`.

- 4) Τέλος, από τον υπολογιστή στον οποίο στείλαμε το κλειδί είτε με την ssh-copy-id είτε με το να το αντιγράψουμε χειρονακτικά, εκτελούμε την εντολή ssh blaxos111333444@

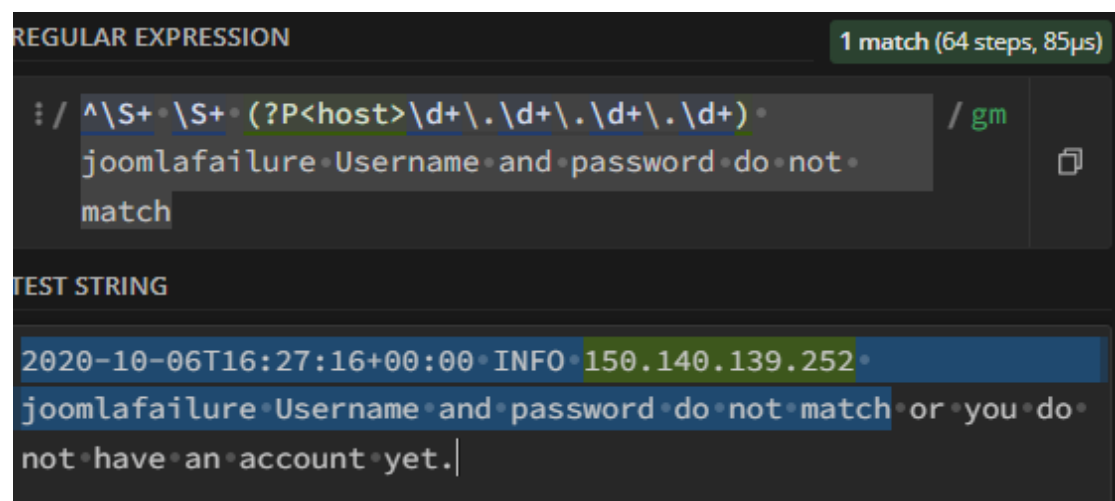
```
blaxos111333444@192.168.2.9: Permission denied (publickey).
feidas111333444@feidas111333444-virtualbox:~$ ssh blaxos111333444@192.168.2.9
blaxos111333444@192.168.2.9: Permission denied (publickey).
feidas111333444@feidas111333444-virtualbox:~$
```

(Επηρεασμένο από πριν, δεν μπορούσα σε αυτό το virtual machine να συνδεθώ στο άλλο, αφού δεν κατάφερα να στείλω το κλειδί πιο πριν. Θα ήθελα να το δείτε και εσείς να το κάνουμε troubleshoot, διότι δεν μπορώ να καταλάβω τι άλλο θα μπορούσα να κάνω).

Εργασία 3

- 1) Τα regular expressions για τα log αρχεία του Joomla και του Nextcloud είναι:

Joomla: `^\S+ \S+ (?P<host>\d+\.\d+\.\d+\.\d+) joomlafailure Username and password do not match`



Nextcloud: `{"reqId":"[A-Za-z0-9]+","level":[0-9]+,"time":"\d{4}-\d{2}-\d{2}T\d{2}:\d{2}:\d{2}([+-]\d{2}:\d{2})?", "remoteAddr":"(?P<host>\d{1,3}.\d{1,3}.\d{1,3}.\d{1,3})".*?"message":"Login failed`

```
REGULAR EXPRESSION 1 match (207 steps, 170µs)

: / {"reqId": "[A-Za-z0-9]+", "level": "[0-9]+", "time": "\d{4}-\d{2}-\d{2}T\d{2}:\d{2}:\d{2}([+-]\d{2}:\d{2})?", "remoteAddr": "(?P<host>\d{1,3}.\d{1,3}.\d{1,3}.\d{1,3})".*?"message": "Login failed" / gm

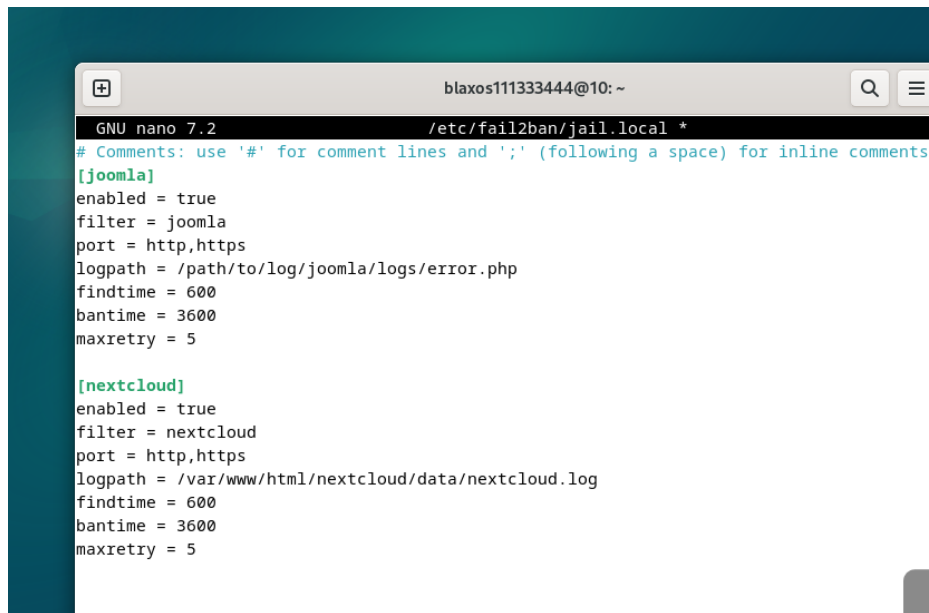
TEST STRING

{"reqId": "VDEzZE0K2wITbT4fNrs1", "level": 2, "time": "2020-10-26T16:04:26+02:00", "remoteAddr": "150.140.139.143", "user": "-", "app": "no-app-in-context", "method": "POST", "url": "/nextcloud/index.php/login", "message": "Login failed: username (Remote IP: 150.140.139.143)", "userAgent": "Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:82.0) Gecko/20100101 Firefox/82.0", "version": "19.0.4.2"}
```

Χρησιμοποιήσαμε την ιστοσελίδα [regex101](#) για να ελέγξουμε τα regular expressions

- 2) Για να δοκιμάσουμε τα φίλτρα, μπορούμε να το κάνουμε με τις εξής εντολές (για το Joomla και το Nextcloud):
- `sudo fail2ban-regex /var/log/joomla/joomla.log /etc/fail2ban/filter.d/joomla.conf`
 - `sudo fail2ban-regex /var/log/nextcloud/nextcloud.log /etc/fail2ban/filter.d/nextcloud.conf`

- 3) Στο αρχείο `jail.local` διαμορφώνουμε για τα φίλτρα:



```
blaxos111333444@10: ~
GNU nano 7.2 /etc/fail2ban/jail.local *
# Comments: use '#' for comment lines and ';' (following a space) for inline comments
[joomla]
enabled = true
filter = joomla
port = http,https
logpath = /path/to/log/joomla/logs/error.php
findtime = 600
bantime = 3600
maxretry = 5

[nextcloud]
enabled = true
filter = nextcloud
port = http,https
logpath = /var/www/html/nextcloud/data/nextcloud.log
findtime = 600
bantime = 3600
maxretry = 5
```

Όπου τα logpaths δεν είναι σωστά καθώς δεν έχουμε εγκαταστήσει Joomla και nextcloud, απλά βάλουμε παραστατικά logpaths για να δείξουμε τη διαμόρφωση.

Στην συνέχεια εκτελούμε `sudo systemctl restart fail2ban`